Compte rendu du TP2.2 Chapitre2 cyber sécurité

Analyse et correction des vulnérabilités

Introduction

L'objectif de ce TP est de passer d'une phase de détection de vulnérabilités à une phase active de remédiation afin de durcir la sécurité des systèmes cibles.

Partie 1 : Analyse des vulnérabilités critiques

1. Vulnérabilités Windows

A. Nom de la vulnérabilité, ex: MS17-010 EternalBlue

- **Quel est le problème :** Le protocole SMBv1 présente des failles permettant l'exécution de code à distance.
- **Quel est le risque** : Prise de contrôle totale de la machine, propagation de ransomwares.
- **Comment exploitable :** Via l'envoi de paquets spécialement conçus vers le port 445

- **Capture d'écran (Nessus - Avant correction) :**

B. Nom de la vulnérabilité, ex: SMB Signing not required

- **Quel est le problème :** Les communications SMB ne sont pas signées.
- **Quel est le risque :** Interception et modification du trafic (Man-in-the-Middle).
- **Comment exploitable :** Un attaquant sur le même réseau peut usurper le serveur.

teutchueng / Plugin #57608

‹ Back to Vulnerability Group

Vulnerabilities 18

MEDIUM SMB Signing not required

Description

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks the SMB server.

Solution

Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digitally sign communications (always)'. On Samba, the setting is called 'server signing'. See the 'see also' links for further details.

See Also

http://www.nessus.org/u?df39b8b3
http://technet.microsoft.com/en-us/library/cc731957.aspx
http://www.nessus.org/u?74b80723
https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html

2. Vulnérabilités Linux

teutchueng / Plugin #10114

‹ Back to Vulnerabilities

Configure | Audit Trail | Launch

Vulnerabilities 24

LOW ICMP Timestamp Request Remote Date Disclosure

Description

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution

Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Output

```
The difference between the local and remote clocks is -296 seconds.
```

To see debug logs, please visit individual host

Port ▲	Hosts

Plugin Details

Severity: Low
ID: 10114
Version: 1.56
Type: remot
Family: Gener
Published: Augus
Modified: Octob

VPR Key Drivers

Threat Recency: No reco
Threat Intensity: Very Lo
Exploit Code Maturity: F
Age of Vuln: 730 days +
Product Coverage: Very
CVSSV3 Impact Score: 1

Vulnérabilité : ICMP Timestamp Request Remote Date Disclosure (Plugin #10114)

- **Quel est le problème ?** La machine répond aux requêtes ICMP de type "Timestamp" (horodatage). Cela permet à n'importe quel attaquant distant d'obtenir l'heure système précise configurée sur votre machine.
- **Quel est le risque ?** Le risque est une **divulgation d'informations**. Bien que jugé "faible", cet accès à l'heure système permet à un attaquant de cartographier plus précisément le réseau ou de tenter de contourner des mécanismes d'authentification basés sur le temps (token temporaires, synchronisation de session, etc.).
- **Comment exploitable ?** Un attaquant envoie un paquet ICMP de type 13 (Timestamp Request) à la machine cible. La machine, par défaut, répond avec un paquet de type 14 (Timestamp Reply) contenant son horodatage interne. Aucun compte utilisateur n'est nécessaire pour effectuer cette requête.

Partie 2 & 3 : Correction et Remédiation

1. Actions sur Windows

- **Commande utilisée pour le pare-feu :** `netsh advfirewall set allprofiles state on`

2. Actions sur Linux

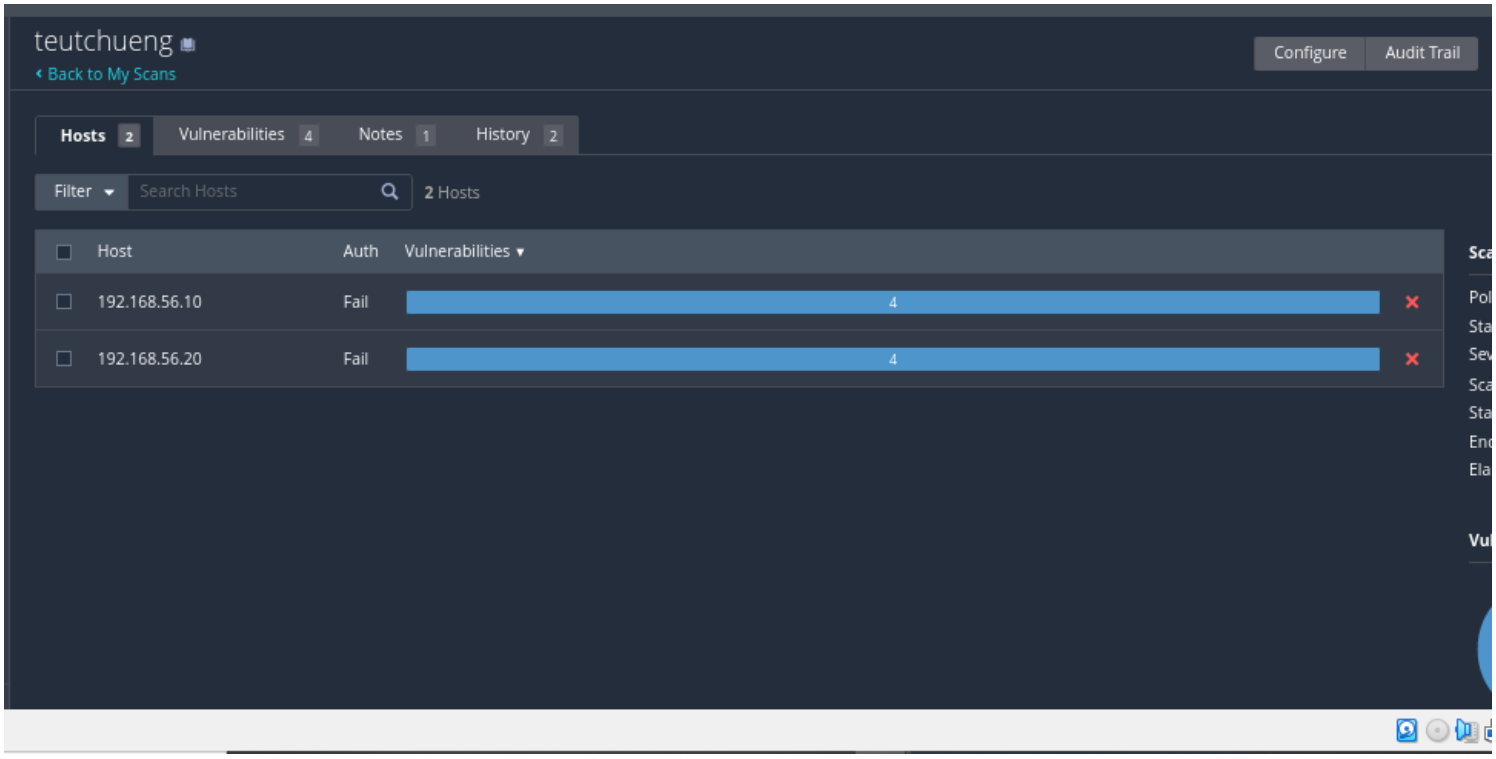
- **Mises à jour :** `sudo apt update && sudo apt upgrade -y`
- **Configuration pare-feu :** `sudo ufw enable`

Partie 4 : Re-scan Nessus et Comparaison

Comparaison des résultats

Résultat final (Scan de vérification)

- **Commentaire :** après mise à jour des paquets et activation des pare-feu, on constate qu'il y'a plus aucune vulnérabilité visible.
- **Capture d'écran (Scan Nessus Après correction) :**



Conclusion

Le durcissement des systèmes via la mise à jour des logiciels, l'activation des pare-feu et la désactivation des services inutiles a permis de réduire significativement la surface d'attaque.